



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Laboratorio di Sicurezza Informatica

Monitoraggio

Marco Prandini

Dipartimento di Informatica – Scienza e Ingegneria

Host IDS – integrity check

- La rilevazione di intrusioni sull'host è tipicamente svolta per mezzo di un *integrity checker*
- Principio:
 - Si memorizza in un database lo stato del filesystem quando è certamente “pulito”
 - Si confronta periodicamente il filesystem col database
- Tra i più diffusi:
 - Tripwire (commerciale)
 - AIDE (fork FOSS di Tripwire)
 - AFICK

<https://www.sans.org/reading-room/whitepapers/detection/ids-file-integrity-checking-35327>

AIDE – uso appropriato

- A seconda del caso, AIDE può essere
 - eseguito come strumento forense, solo se si sospetta / si verifica un'irruzione
 - programmato per segnalare regolarmente qualsiasi cambiamento interessante
 - Due problemi:
 - reimpostare periodicamente il database per interrompere la segnalazione di modifiche non dannose ai file
 - difendere l'integrità del binario e del database di AIDE!
- Per ridurre il rischio di eseguire un AIDE compromesso / su un DB compromesso:
 - utilizzare le firme HMAC per il file di configurazione e il DB
 - masterizzare il DB su di un supporto non riscrivibile
 - eseguire il software da un sistema diverso e affidabile
 - oppure, se non se ne dispone, da un supporto di ripristino
 - fermo macchina!

AFICK

- Configurazione molto simile ad AIDE ma con un numero minore di check supportati
- Caratteristiche
 - Può essere eseguito da media ottici read only per garantire la sua stessa integrità
 - Report CSV semplici e facili da importare in altri sw
 - Scritto in Perl, molto portabile

<http://afick.sourceforge.net/>

Log di sistema

- I log (diari) tenuti dal sistema sono indispensabili per la diagnostica in generale, e in particolare per rilevare attività malevole o sospette
 - da processi utente
 - da processi kernel
- La loro stessa sicurezza va garantita, o l'attaccante semplicemente cancellerà le proprie tracce
 - Usare appropriatamente un integrity checker
 - Replicarli su macchine remote
- Logging su server remoto
 - Vantaggio aggiuntivo: centralizzazione
 - Implementazioni avanzate: shadow loggers
 - Problema: diventa un bersaglio appetibile
 - DoS

Analisi e gestione dei log

■ Non basta scrivere gli eventi da qualche parte

■ Analisi

- estrazione del significato dei messaggi
- serie temporali
- correlazione file multipli
- reazione in tempo reale

■ Gestione

- spazio
- archiviazione

"Vedi la foresta, ma anche gli alberi"
– splunk.com

SIEM

■ Aggregazione dei dati

- raccoglie log / eventi da più fonti
- normalizza e consolida i dati
- sistema di interrogazione centralizzato

■ Correlazione

- collega eventi con attributi comuni in pacchetti significativi
- genera automaticamente avvisi in base a condizioni specifiche

■ Monitoraggio

- grafici per visualizzare lo stato corrente
- grafici relativi alla conformità

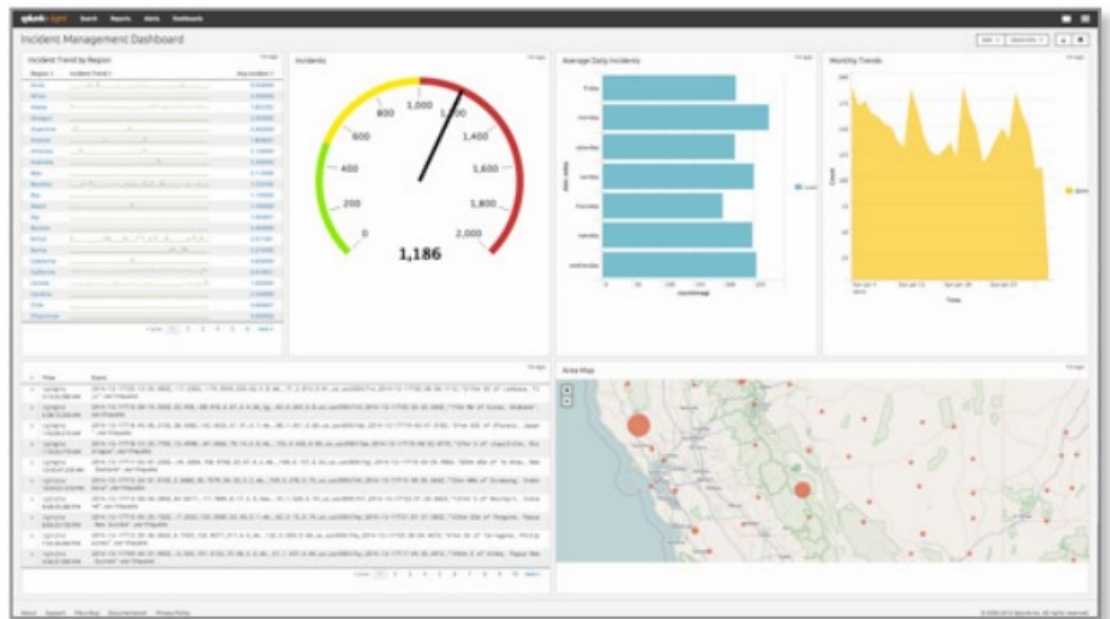
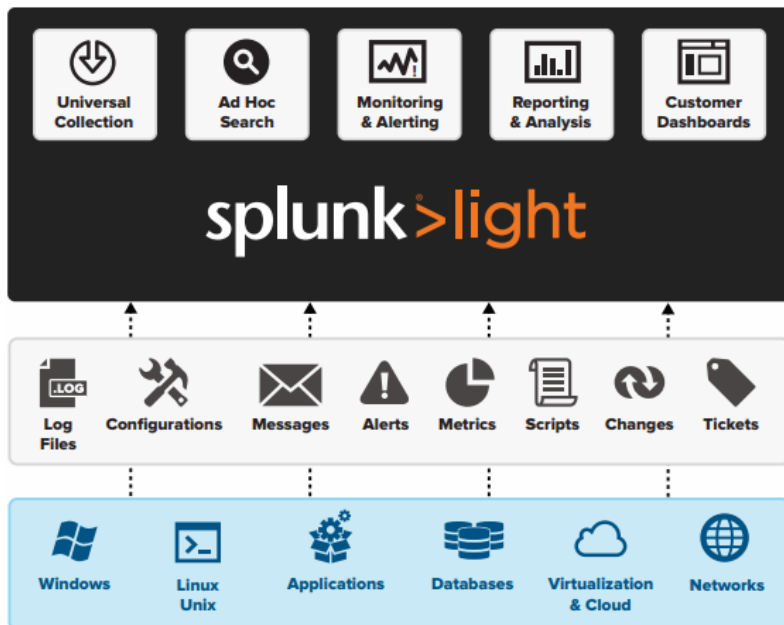
■ Ritenzione

- conservazione a lungo termine
- analisi forense



SIEM

- Stanno evolvendo verso gestione integrata
 - qualsiasi tipo di "dato macchina" → **normalizzazione**
 - algoritmi di machine learning
 - reportistica avanzata
 - on premise o SaaS



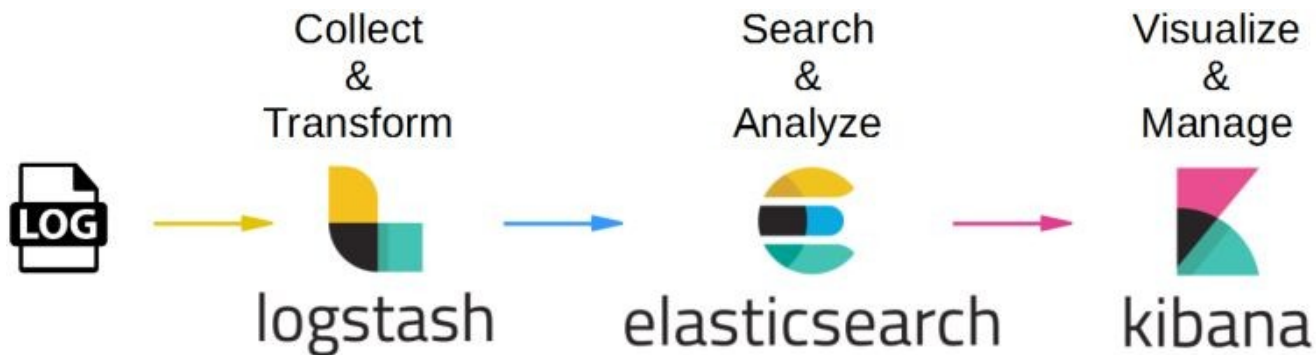
Analisi dei dati di ispirazione cloud

■ Stack Elastic, Open Source

- <https://www.elastic.co/>
- Raccolta e esplorazione dei dati di log
- definizione di un **Elastic Common Schema** per normalizzare
 - aperto, semplice, estendibile
 - limitato all'ambiente Elastic, verboso, non facile manutenzione delle customizzazioni

■ Composto dai tre programmi:

- **Logstash**: Pipeline di elaborazione dei log
- **Elasticsearch**: Database Nosql
- **Kibana**: Visualizzatore web-based per documenti in Elasticsearch



Un esempio di SIEM OSS: Wazuh

■ Open source fork di OSSEC

- per vedere rapidamente cosa è cambiato
<https://wazuh.com/migrating-from-ossec/>
- nel seguito si fa riferimento alle caratteristiche originali di OSSEC

■ Funzionalità principali

- Verifica della compliance a policy di sicurezza **OpenSCAP**
- Raccolta dei log, analisi e conservazione centralizzata
 - Integrazione con Elastic stack
- Filesystem integrity checking
- Host-based IDS – non servono sonde in rete
 - monitoraggio del Windows registry
 - scansione per malware, rootkit, anomalie, processi offuscati, syscall inconsistenti, ...
- Reazioni attive
 - built-in: RTBL (Real Time Black Listing)
 - qualsiasi cosa via scripting

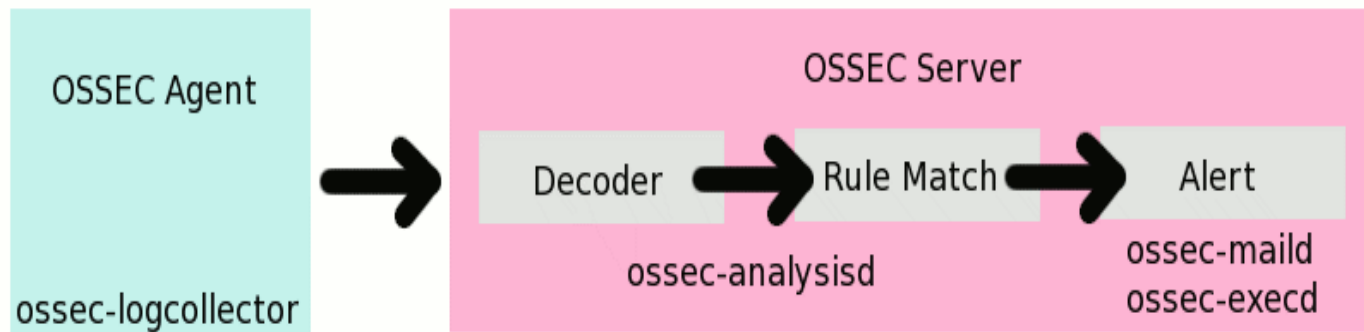
OSSEC

■ Due modalità di funzionamento

- locale, client-server

■ Modalità client-server

- i client ricevono la configurazione da un server
- i client inviano i log al server su canale cifrato



■ Comunicazione

- standard syslog (UDP:514)
- compressione
- cifratura simmetrica (blowfish con chiavi scambiate manualmente)

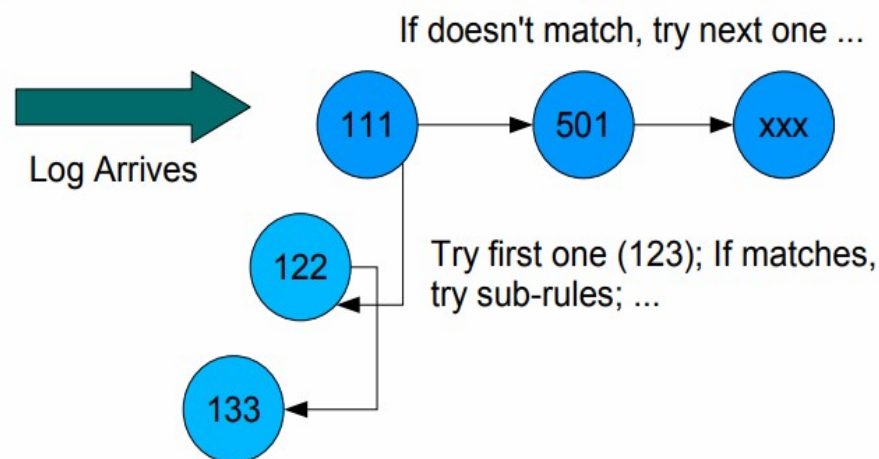
OSSEC config / decoders e rules

■ Parsing dei log file configurabile per mezzo di *decoders*

- monitoraggio di file multipli
- regole di parsing ed estrazione scritte in XML
- forniscono i campi utili per l'attivazione delle *rules*

■ Analisi dei dati per mezzo di *rules*

- scritte in XML
- componibili in gerarchia
 - livelli di priorità 1-15
- ruleset pre-configurati per i servizi più diffusi



■ Esempi

<http://ossec-docs.readthedocs.io/en/latest/manual/rules-decoders/create-custom.html>

<https://sevenminuteserver.com/post/2010-09-25-writing-custom-ossec-rules/>

OSSEC config / alerts

■ Azioni predefinite – molte tra cui

- Vari tipi di attacco ad applicazioni web
- Attacco di forza bruta agli account via SSH
- Buffer overflow e terminazioni anomale di processi
- Eccezioni alle regole di controllo dell'accesso del traffico
- Utilizzo di sudo

■ Creazione di alert personalizzati

- scattano in funzione delle *rules*
- possono eseguire
 - logging dell'evento
 - invio di e-mail, sms, ...
 - esecuzione di uno script
- possibilità di **esecuzione su host multipli**

OSSEC funzioni avanzate

- Monitoraggio dell'output di script, ad esempio scan NMAP
 - alert quando un host sotto controllo cambia

https://ossec.github.io/docs/manual/notes/nmap_correlation.html
- Reportistica
 - summary
 - database per successive elaborazioni
 - web UI (deprecata)
- <https://ossec.github.io/>

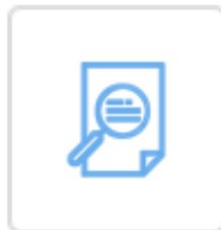
Wazuh functions



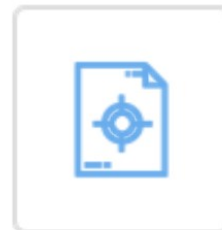
Security
Analytics



Intrusion
Detection



Log Data
Analysis



File Integrity
Monitoring



Vulnerability
Detection



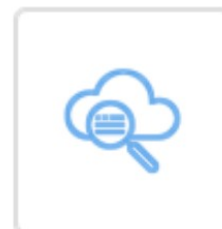
Configuration
Assessment



Incident
Response



Regulatory
Compliance



Cloud
Security



Containers
Security

■ <https://wazuh.com/>